

Arquitectura de Seguridad en SQL Server: Fortificación de la Base de Datos

Implementación técnica, buenas prácticas y auditoría del
entorno de producción GradosTitulos



Fecha de despliegue: 24 de Mayo, 2024



Arquitecto Principal: Equipo de Seguridad de Datos



Entorno: Producción corporativa

La Estrategia: Defensa en Profundidad



Un enfoque estructurado para transformar un modelo por defecto en una arquitectura invulnerable, aplicando el **principio de mínimo privilegio** en cada vector de ataque.

Capa 1: Perímetro de Acceso | El Desafío de la Autenticación Mixta

Personal Académico (Interno)



Mecanismo: Autenticación Windows

UPLA\TrabajadoresInternos

Justificación: Delega la validación al dominio corporativo (Kerberos/NTLM). Elimina la gestión de contraseñas duplicadas. Integración nativa SSO.

Consultores (Externos)



Mecanismo: Autenticación SQL Server

log_consultor_externo

Justificación: Aislamiento del dominio interno para usuarios temporales. Uso obligatorio de políticas del SO.

Capa 1: Perímetro de Acceso | Implementación T-SQL: Modo Mixto y Políticas

CONFIGURACIÓN AUTENTICACIÓN MIXTA

```
SQL Server Management Studio - SQL Server Management Studio
SQL Server Enterprise Edition (64-bit) - SQL Server Management Studio
File Edit View Project Tools Window Help
New Query
-- 1. Habilitar el modo de autenticación mixta en la instancia
USE master;
GO
EXEC xp_instance_regwrite
N'MSFT_SQLSERVER_ENUM',
N'Software\Microsoft\ASSQLServer\MSSQLServer',
N'LoginMode',
REG_DWORD,
2; -- 2 y Modo Mixto (Requiere reiniciar el servicio)

-- 3. Verificar el modo de autenticación actual
SELECT
CASE
WHEN SERVERPROPERTY('IsIntegratedSecurityOnly') = 1
THEN 'Solo Windows Authentication'
ELSE 'Modo Mixto (Windows y SQL Server)'
END AS ModoAutenticacion,
SERVERPROPERTY('IsIntegratedSecurityOnly')
AS IsIntegratedSecurityOnly;
GO
```



Configuración a nivel de registro:
Habilitación programática del
modo mixto para aceptar
tanto tokens de Windows
como logins nativos. Requiere
reinicio del servicio.

CREACIÓN DE LOGINS

```
SQL Server Management Studio - SQL Server Management Studio
SQL Server Enterprise Edition (64-bit) - SQL Server Management Studio
File Edit View Project Tools Window Help
New Query
USE master;
GO
-- 3. Acceso para personal interno (Autenticación Windows)
CREATE LOGIN [UPLA\trabajadoresinternos] FROM WINDOWS;
GO
-- 4. Acceso para consultores externos (Autenticación SQL Server)
CREATE LOGIN [log_consultor_externo]
WITH PASSWORD = @'F8eoultor_Ectekn0_2023@',
CHECK_EXPIRATION = ON,
CHECK_POLICY = ON;
GO
```



Fortalecimiento del Login SQL:
Garantiza contraseñas robustas
y obliga a la rotación
periódica, mitigando ataques
de fuerza bruta en cuentas
externas.

Capa 1: Perímetro de Acceso | Observabilidad: Monitoreo en Tiempo Real

3. Sesiones Activas

SQLQuery2.sql - (local)SQL2022 (66 (68) X

```
1 USE GradosTitulos;
2 GO
3
4 -- Conexiones vivas y tipo de autenticación
5 SELECT
6     session_id,
7     original_login_name,
8     auth_scheme,
9     host_name,
10    status,
11    program_name,
12    login_time_desc
13 FROM sys.dm_exec_sessions
14 WHERE is_user_process = 1
15 ORDER BY login_time_desc;
16 GO
```

Results Messages

	session_id	original_login_name	auth_scheme	host_name	status	login_time	program_name
▶	82	UPLA\TrabajadoresInternos	NTLM	PC-UPLA-DES-001	running	2024-05-15 11:27:12.917	Microsoft SQL Server Mar
	84	log_consultor_externo	SQL	LAPTOP-CONS-002	running	2024-05-15 11:22:43.600	Microsoft SQL Server Mar

✔ Query executed successfully.

✔ Completed | 00:00:00.004 | (local)SQL2022 (16.0 RTM) | sa (68) | GradosTitulos | 5 rows

Vistas de Administración Dinámica (DMV)



Objeto: sys.dm_exec_sessions

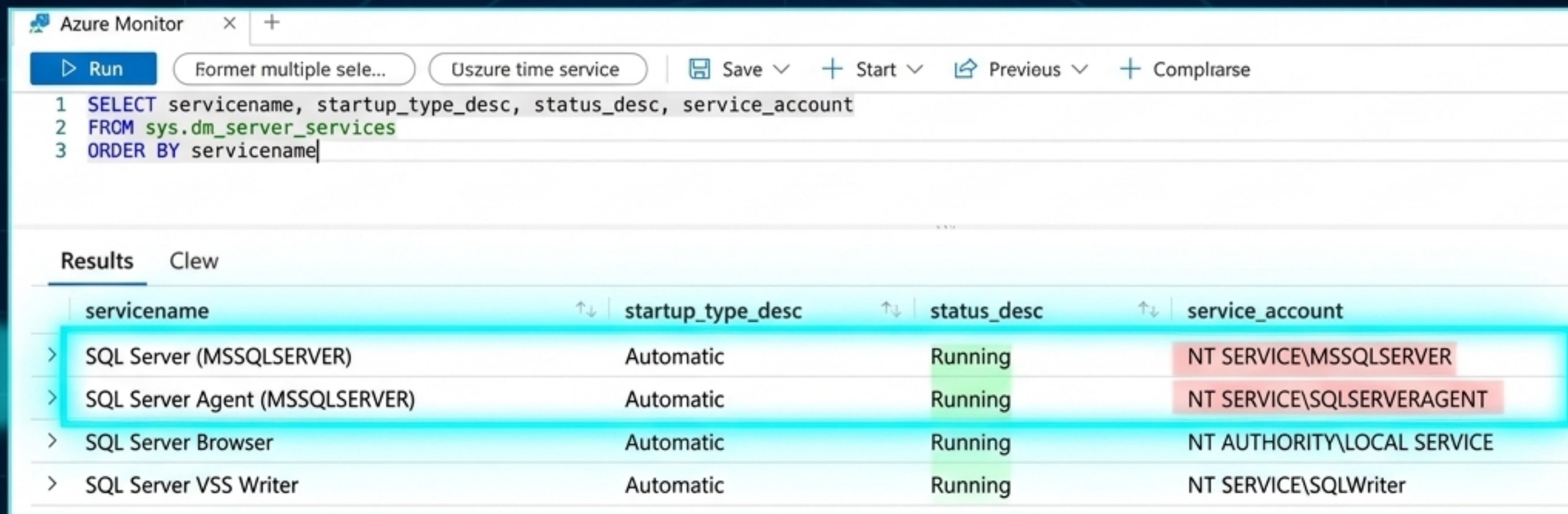


Propósito: Permite auditar en tiempo real qué esquema de autenticación (SQL o NTLM/Kerberos) en a SQL o NTLM/Kerberos) está utilizando cada proceso de usuario activo.



Resultado: Detección inmediata de anomalías de acceso y confirmación del principio de mínimo privilegio.

| Capa 2: Endurecimiento de Red | Superficie de Ataque: Cuentas de Servicio



Azure Monitor

Run | Former multiple sele... | Uzure time service | Save | Start | Previous | Complrarse

```
1 SELECT servicename, startup_type_desc, status_desc, service_account
2 FROM sys.dm_server_services
3 ORDER BY servicename
```

Results | Clew

servicename	startup_type_desc	status_desc	service_account
> SQL Server (MSSQLSERVER)	Automatic	Running	NT SERVICE\MSSQLSERVER
> SQL Server Agent (MSSQLSERVER)	Automatic	Running	NT SERVICE\SQLSERVERAGENT
> SQL Server Browser	Automatic	Running	NT AUTHORITY\LOCAL SERVICE
> SQL Server VSS Writer	Automatic	Running	NT SERVICE\SQLWriter

Principio de Mínimo Privilegio (Nivel OS)

Solución Aplicada: Uso de cuentas virtuales administradas por Windows.

Justificación: El motor de base de datos **nunca debe ejecutarse bajo cuentas de administrador local**. Estas cuentas virtuales poseen únicamente los permisos estrictamente necesarios sobre el sistema operativo para ejecutar SQL Server, aislando el servicio y reduciendo drásticamente la superficie de ataque.

Capa 2: Endurecimiento de Red | Conectividad Segura y Cifrado en Tránsito

Network connectivity

Public network access ⓘ Enabled

Private endpoint connections ⓘ 0

Allow Azure services to Allow Azur... ⓘ ☐ On ☒ On

Firewall rules

Rule name	Start IP	End IP	
OficinaPrincipal	192.168.1.0	192.168.1.255	...
OficinaPrincipal	192.168.1.0	192.168.1.255	...
SedeSecundaria	172.16.0.0	172.16.255.255	...
Add a rule rule...			

Force minimum TLS version ⓘ

☐ 1.0 ☐ 1.1 ☒ 1.2 Connections will be encrypted with a minimum TLS version of 1.2.

Restricción por IP

Configuración de reglas explícitas limitando el acceso exclusivamente a rangos corporativos aprobados (OficinaPrincipal, SedeSecundaria).

Cifrado Moderno Obligatorio

Forzar el uso exclusivo de TLS 1.2. Protege la información en tránsito contra interceptación (Man-in-the-Middle), eliminando permanentemente las vulnerabilidades críticas presentes en protocolos obsoletos.

Capa 3: Estructura de Roles | Jerarquías y Contenedores Lógicos



Concepto Clave: La gestión de permisos no se asigna por usuario individual. Los roles de base de datos agrupan permisos a nivel de contenedor lógico (SCHEMA), securizando la administración a escala.

Capa 3: Estructura de Roles | Despliegue de Infraestructura Segura

```
Query 1 x
1  -----
2  -- CREACION DE ROLES PERSONALIZADOS
3  -- Base de datos: GradosTitulos
4  -----
5
6  -- 1. Rol para el esquema de Tramite
7  IF NOT EXISTS (SELECT * FROM sys.database_principals
8  WHERE name = N'rol_esquema_tramite' AND type = 'R')
9  BEGIN
10     CREATE ROLE [rol_esquema_tramite];
11     PRINT 'Rol [rol_esquema_tramite] creado correctamente.';
12 END
13 GO
14 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA::Tramite
15 TO [rol_esquema_tramite];
16 GO
17
18 -- 2. Rol de nivel Supervisor
19 IF NOT EXISTS (SELECT * FROM sys.database_principals
20 WHERE name = N'rol_esquema_supervisor' AND type = 'R')
21 BEGIN
22     CREATE ROLE [rol_esquema_supervisor];
23     PRINT 'Rol [rol_esquema_supervisor] creado correctamente.';
24 END
25 GO
26
27 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA::Tramite
28 TO [rol_esquema_supervisor];
29 GRANT SELECT ON SCHEMA::Documento TO [rol_esquema_supervisor];
30 GO
```

Técnica: Scripts Idempotentes

Verificación sistemática de existencia previa antes de la creación del rol.

Justificación:

Transforma un script destructivo o frágil en una operación segura. Permite que el código se ejecute múltiples veces en canalizaciones de automatización (CI/CD) o mantenimientos rutinarios sin generar errores de colisión de objetos en producción.

Capa 4: Control Granular | El Motor de Autorización SQL



La Supremacía del DENY

En el motor de SQL Server, una denegación explícita (DENY) tiene **prioridad absoluta e irrevocable** sobre cualquier concesión, independientemente de la pertenencia a otros roles.

Separación de Funciones

Un usuario no puede alterar datos fuera de su jurisdicción estricta, blindando la integridad de esquemas críticos.

Control Administrativo

El permiso GRANT CONTROL se reserva exclusivamente para administradores integrales, evitando el uso excesivo del rol del sistema sysadmin.

Capa 4: Control Granular | Aplicación Práctica del Aislamiento

```
SQL Server Management Studio (SSMS)

-- Permisos de lectura para el rol evaluador en el esquema Evaluacion
GRANT SELECT ON SCHEMA::Evaluacion TO [rol_evaluador_tesis];
GRANT SELECT ON SCHEMA::Academico TO [rol_evaluador_tesis];

-- Permitir insertar y actualizar observaciones
GRANT INSERT, UPDATE ON SCHEMA::Evaluacion.Observaciones TO [rol_evaluador_tesis];

-- Bloquear modificaciones en el esquema academico
DENY INSERT, UPDATE, DELETE ON SCHEMA::Academico TO [rol_evaluador_tesis];

-- Permisos de operador en el esquema Tramite
GRANT SELECT, INSERT ON SCHEMA::Tramite TO [rol_nivel_operador];

-- Permisos de supervisor en Tramite y lectura en Documento
GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA::Tramite TO [rol_nivel_supervisor];
GRANT SELECT ON SCHEMA::Documento TO [rol_nivel_supervisor];

-- Control total para el administrador
GRANT CONTROL ON DATABASE::GradosTitulos TO [rol_nivel_administrador];
GO
```

Bloqueo Matemático: Previene de forma absoluta cualquier modificación de notas por parte de los evaluadores, garantizando la integridad de los registros académicos.

Delegación Segura: Entrega la gestión total de la base de datos sin comprometer la seguridad a nivel de la instancia completa del servidor.

Capa 5: Protección de Datos | Cifrado Transparente (TDE)



Protección en Reposo

Asegura los archivos físicos y respaldos contra el robo de medios magnéticos.

Cifrado Transparente

Utiliza encriptación fuerte sin requerir modificaciones en el código de las aplicaciones existentes.

Capa 5: Protección de Datos | Azure Key Vault y Verificación

1 GradosTitulos | Data encryption

Transparent data encryption

Transparent data encryption encrypts your databases, backups, and logs in place without any changes to your database. To encrypt or decrypt change to data database.

Learn more

Transparent data encryption

ON OFF

Encryption key

SQL Server Key (RSA)

Encrypt key

Key vault

contoso-vault

Original key vault

Key version

5b1bc7ec8c3b0c7c01c2c47721822c

Change key version

Transparent data encryption is enabled. All data, tables, and logs for this database are encrypted in place.

1. Activación Transparente

2 contoso-vault | Keys

Find lost keys restore from soft delete or backups

Search keys

Type: All Status: All

Showing 14 of 44 results

Name	Status	Expiration date
SQLServerKey	Disabled	1/1/3916
106Key3024	Enabled	8/15/3029
106KeyKey	Disabled	1/15/3029
106KeyKey	Enabled	5/25/3024

Key versions

Version	Status	Activation date	Expiration date
V75b4dC6e3b0c7c01c2c47721822c	Disabled	1/1/2023	7/10/2033
MT7A9C5b4dC6e3b0c7c01c2c47721822c	Enabled	1/1/2023	7/10/2033
V75b4dC6e3b0c7c01c2c47721822c	Disabled	1/1/2022	7/10/2034

Justificación: Separación de funciones. Los administradores gestionan los datos; el equipo de Seguridad gestiona y rota las claves criptográficas de forma aislada.

2. Bóveda Externa de Claves

3 GradosTitulos (contoso) | Query editor (SQL)

Run New Query Open query

Run New Query Save query Export data

```
SELECT
  database_name AS DatabaseName,
  encryption_state_desc AS PercentComplete,
  encryption_state_desc AS Servers,
  percent_complete AS PercentComplete
FROM
  sys.dm_database_encryption_keys;
```

Results Messages

DatabaseName	EncryptionState	PercentComplete
GradosTitulos	ENCRYPTED	120

Query succeeded | 1 row

DMV: sys.dm_database_encryption_keys confirma que el estado criptográfico es activo y seguro.

3. Verificación de Estado

Capa 6: Vigilancia Continua | Sistema Integral de Auditoría

```
-- Enable server level auditing (if not already enabled)
IF NOT EXISTS (SELECT * FROM sys.server_audit_specifications
               WHERE name = 'ServerAudit')
BEGIN
    CREATE SERVER AUDIT SPECIFICATION [ServerAudit]
    FOR SERVER AUDIT [GradosTitulos_Audit]
    ADD (SUCCESSFUL_LOGIN_GROUP),
    ADD (FAILED_LOGIN_GROUP),
    ADD (DATABASE_LOGOUT_GROUP)
    WITH (STATE = ON);
END
GO
```

Alcance y Grupos de Acción

-  **Trazabilidad Dual:** SQL Server Audit opera de forma nativa capturando eventos tanto a nivel de instancia como de base de datos.
-  **Accesos Legítimos:** SUCCESSFUL_LOGIN_GROUP rastrea el comportamiento estándar.
-  **Detección de Amenazas:** FAILED_LOGIN_GROUP alerta tempranamente sobre ataques de fuerza bruta o credenciales comprometidas.
-  **Protección DML/DDI:** Auditoría ininterrumpida de accesos y modificaciones en los esquemas críticos (Tramite).

Capa 6: Vigilancia Continua | Almacenamiento Inmutable e Integración SIEM

GradosTitulos | Auditing
SQL Database

Search

Overview
Activity log
Tags
Diagnose and solve problems
Quick start
Query editor preview

Settings
Configure
Connection setups
Properties
Locks

Data management
Settings
Sync to other database
Export data

Security
Networking
Defender for Clouds
Transparent data encryption
Auditing
Dynamic data tracking
Identity
Threat detection

SQL Server auditing tracks database basen and works them to an audit log in Azunt Storage
[Learn more](#)

Auditing
☒ On ☐ Off

Storage account *
sglgradesauditing

Retensing
[Create new](#)

Audit log destination
☒ Blob storage
☐ Log Analytics workspace
☐ Event Hub

Built storage path *
sglgradesauditing(gradesTitulos)

Auditing is converted to the storage account
sglgradesauditing

Retention (days) *
365

Audit log format
☒ JSON ☐ Less

Advanced settings

stgradosauditlogs | Log viewer
Malage account

Refresh Change view Download Reverts Queries

Viewing logs for last 24 hours from 5/21/2023, 10:30:21 AM to 5/22/2021, 10:29:21 AM

Total records: 1,248
Successful records: 1,102
Failed records: 146
Result: 4

Search Add new Time range: Last 24 hours

Time (UTC)	Event	Database	User	Action	Client IP
> 5/22/2025, 10:13:14 AM	LOGGIN	master	CONF0SSlgulana	LOGIN	10.12.18
> 5/22/2023, 10:15:37 AM	LOGGIN	GradosTitulos	CONF0SSlgalsnna	LOGIN	Success
> 5/22/2023, 10:15:57 AM	LOGGIN	GradosTitulos	CONF0SSlgvrane	LOGIN	Success
> 5/22/2021, 15:38:89 AM	LOGGIN	master	CONF0SSlgymarka	LOGIN	10.12.18
> 5/22/2021, 15:38:39 AM	LOGGIN	GradosTitulos	CONF0SSlgmenzis	LOGIN	10.12.18
> 5/22/2021, 15:18:33 AM	FAILSD, \OGN	master	CONF0SSlgymenendia	Failure	Failure
> 5/22/2021, 10:35:38 AM	LOGGIN	GradosTitulos	CONF0SSlgslana	LOGIN	Success
> 5/22/2021, 15:35:39 AM	LOGGIN	GradosTitulos	CONF0SSlgnsanca	LOGOUT	Success
> 5/22/2021, 15:38:85 AM	LOGGIN	master	CONF0SSlgynorka	LOGIN	10.12.18
> 5/22/2021, 19:58:53 AM	FAILSD, \OGN	master	CONF0SSlgymoszes	Failure	Failure
> 5/22/2021, 19:15:17 AM	LOGGIN	GradosTitulos	CONF0SSlgalperia	LOGIN	Success
> 5/22/2021, 19:15:37 AM	LOGGIN	GradosTitulos	CONF0SSlgvrane	LOGOUT	10.12.18
> 5/22/2021, 16:37:35 AM	LOGGIN	master	CONF0SSlgynska	Failure	Success
> 5/23/2023, 16:58:39 AM	LOGGIN	GradosTitulos	CONF0SSlgmenaa	Failure	10.12.18

1 of 84 Next >

Integración SIEM

Exportación nativa en formato estructurado JSON. Ideal para la ingesta automatizada e inmediata en plataformas empresariales de análisis forense y correlación de eventos.

Almacenamiento Inmutable

Los registros de eventos se envían externamente a Azure Blob Storage. Esto previene matemáticamente que un atacante borre sus huellas. Se fuerza una retención estricta de 365 días para cumplimiento normativo.

Conclusión: Un Entorno de Producción Invulnerable



Pillar 1	Pillar 2	Pillar 3	Pillar 4
Perímetro Controlado	Acceso Mínimo	Datos Protegidos	Cumplimiento
Autenticación mixta auditada en tiempo real y conectividad cifrada forzada bajo TLS 1.2.	Jerarquía de roles granulares. El bloqueo explícito (DENY) blindo de manera absoluta la integridad académica.	Cifrado transparente (AES-256) del almacenamiento físico, con llaves gestionadas y rotadas en Azure Key Vault.	Auditoría integral exportada a almacenamiento inmutable externo, lista para análisis forense por 365 días.

El despliegue GradosTitulos cumple rigurosamente con los estándares empresariales de ciberseguridad, asegurando confidencialidad, integridad y trazabilidad.